

AI THREAT ASSESSMENT WORKBOOK

Digital Content #7 — Non-Human Identities: You Offboard People. You Never Offboard This.

Purpose: Assess your organization’s exposure to Non-Human Identity (NHI) threats — where machine credentials (service accounts, API keys, tokens, certificates, OAuth apps) and AI agents operate with standing, overprivileged, reused, or unowned access that no human lifecycle governs. Inventory your machine identities, map the gap, assign ownership, and build a prioritized response plan.

01 Exposure Check

Answer Yes / No / Unknown for your environment. Every Unknown is a gap. Three or more Unknowns = this is your next tabletop agenda.

Question	Yes	No	Unknown / Gap Notes
Do we have a current inventory of every non-human identity — service accounts, API keys, tokens, certificates, OAuth apps, workload identities, and AI agents?			
Does every non-human identity have a named human owner and a documented business purpose?			
Can we distinguish AI agent identities from static machine identities, and do we govern agents as their own tier?			
Are any credentials long-lived (never rotated) or shared / reused across more than one integration?			
Do we scan repositories, CI logs, and config files for leaked secrets — and remediate what we find?			
Are machine-identity actions baselined, so deviations (new endpoints, scopes, or origin) raise an alert?			
Do we retire non-human identities on a lifecycle tied to a service or project — not to the person who created them?			
Could we offboard a machine identity as fast and reliably as we offboard a departing employee?			

MACHINE IDENTITY INVENTORY (list known non-human identities, their type and scope, owner, and whether each is an AI agent)

Identity / Name	Type / Scope / Access	Owner	Agent?

02 Privilege, Secret & Reuse Audit

A leaked secret becomes a breach when the identity is overprivileged, reused, or never rotated. Audit scope, rotation, and reuse for every identity.

Question	Yes	No	Unknown / Gap Notes
For each known identity, has the full permission scope been reviewed and reduced to least privilege?			
Are identities with access to sensitive data, production systems, or money movement explicitly identified?			
Is there a process to detect scope creep and credential reuse across integrated platforms?			
Are long-lived secrets being replaced with short-lived, auto-rotated credentials or workload federation (OIDC)?			
Is there alerting when an identity that historically only consumed tokens begins minting new ones?			
Have we assessed whether a leaked secret (repo, CI log, fork) could be assumed without tripping a single alert?			

PRIVILEGE & SECRET REVIEW: For each high-risk identity, document scope, rotation status, and reuse

Identity	Scope / Access	Long-Lived / Reused?	Gap / Action

03 Detection Baseline

Machine identities don't trip alerts built for people — they never log in, never answer MFA, and have no human baseline to deviate from. Detection must be identity-aware.

Question	Yes	No	Unknown / Gap Notes
Does your SIEM or identity platform baseline normal machine behavior and flag deviations?			
Is there an inventory and rotation cadence that surfaces stale, dormant, or never-rotated credentials?			
Do you have behavioral monitoring deployed for AI agents with access to sensitive systems?			
Is there detection for token-minting or privilege escalation initiated by a non-human identity?			
Can you detect the same credential authenticating from two infrastructures at once (reuse or theft)?			
Is secrets-scanning coverage in place across repositories, CI pipelines, and config stores?			
Have you tested detection with a simulated assumed-credential scenario?			

04 Governance Gap — Who Owns What

A non-human identity’s access is real whether or not anyone owns it. Map ownership across inventory, privilege, detection, and lifecycle before an incident surfaces the gap.

Function	Owner (Name / Role)	Last Reviewed	Gap
Machine identity inventory & continuous discovery			
Ownership assignment for every non-human identity			
Least-privilege scoping & reuse elimination			
Secret rotation & long-lived credential elimination			
NHI behavioral detection & monitoring			
NHI lifecycle, offboarding & dormant-identity sweeps			
AI agent authorization & distinct review tier			

05 Five Questions for Your Next Executive Meeting

Bring these to the board. If the honest answer to the first is “we don’t know,” that is the finding.

#	Question	Your Answer / Status
01	Do we have an inventory of every non-human identity with delegated or standing access to our systems — and does each have a named owner?	
02	If a machine credential were assumed today, how long before we would know, and how would we reconstruct what it did?	
03	Which AI agents hold privileged or sensitive access — and what can each reach beyond its stated job?	
04	Can we offboard a machine identity as fast and reliably as we offboard a departing employee?	
05	What is the business justification for the non-human identities in our environment with the broadest, longest-lived access?	

06 Directives — Assign an Owner and a Date

Four moves, in order — inventory, constrain, detect, offboard. Assign each directive an owner and a target date.

#	Audience	Directive	Owner	Done By
01	CISO	Build a machine-identity inventory. Enumerate every service account, API key, token, certificate, OAuth app, workload identity, and AI agent. If it authenticates and isn't a person, it's on the list.		
02	CISO	Assign a named human owner and a business purpose to every non-human identity. Ownerless identities are revoked, not documented.		
03	CISO	Tag AI agents as their own identity tier and govern them separately. They act on credentials, inherit adjacent scopes, and mint new ones — a static API key does none of that.		
04	CISO	Scope every identity to a single job and eliminate reuse across integrations. One identity, one job, one blast radius.		
05	CISO	Eliminate long-lived secrets. Move to short-lived, auto-rotated credentials and workload federation (OIDC) wherever the platform allows.		
06	CISO	Bound AI agent authority explicitly: define what each agent can reach, what it may mint, and a hard time-to-live. Authority without a TTL is authority forever.		
07	IR	Baseline normal machine behavior and alert on deviation — new endpoints, scopes, or origin — and on token-minting from identities that previously only consumed.		
08	IR	Deploy secrets scanning across repositories, CI pipelines, and config stores, and wire NHI telemetry into the SOC. Treat a leaked secret as an active intrusion path.		
09	IR	Stop treating “the credential was valid” as “the action was authorized.” Build the capability to distinguish sanctioned automation from an assumed credential.		
10	IR	Offboard NHIs on a lifecycle tied to the service, test revocation (know what breaks and what inherits), and run dormant-identity sweeps. Rank by exposure: overprivileged + long-lived + unmonitored = highest.		

Assessment prepared by Matsui LLC · matsuihq.ai